OCCPL Innovations

Multi-Product SaaS Platform

Phase plan and project status report

Overall	Phases 1–9 and Billing (Razorpay) complete. Awaiting approval for Phase 10 (Deployment).
Progress	9 of 10 phases plus billing complete.
Tests passing	Backend: 80 unit/slice tests and 77 integration tests against real MySQL 9.7, Keycloak 26.8.1, Redis 8.10 and SMTP; 2 sample-product tests; 1 end-to-end test across Keycloak, Core and the sample product. Frontend: 49 tests, lint, format and production build; browser walkthrough of both portals against the Docker stack with real Keycloak sign-in and MFA. Load test with 1 million users and a backup/restore drill with measured results.
Try it	Local Docker stack: API docs with Keycloak sign-in at http://localhost:8080/swagger-ui.html; every outgoing email (e.g. invitations) in the Mailpit inbox at http://localhost:8025; sample Notes product API at http://localhost:8090. Admin portal (Super Admin and Company Admin) at http://localhost:4200.
Not yet verified	GitHub CI has not run yet (first run on next push). Docker image build stages could not run in the development sandbox (no network inside docker build); runtime images were verified. Razorpay itself is not reachable from the sandbox: billing was tested against a stand-in that follows Razorpay's published API, so a test-mode payment must be tried before going live.
Next step	Phase 10 (Deployment) on approval. Before live payments: decide GST handling (D-11) and run one Razorpay test-mode payment. Before sizing production: confirm the service targets (D-6) and repeat the load test on staging hardware.

Phase overview

#	Phase	Status	Scope
1	**Discovery & architecture**	Done	Architecture, data model, security model, API inventory, backlog, ADRs
2	**Foundation**	Done	Backend & frontend skeletons, Docker stack, CI, error handling, observability
3	**Identity & access**	Done	Keycloak login mapping, roles & permissions, company-level checks, MFA, rate limiting
4	**Company & membership management**	Done	Company lifecycle, invitations, member roles, audit trail
5	**Product catalogue**	Done	Product registration, versioned configuration, features
6	**Plans, subscriptions & entitlements**	Done	Plans, prices, limits, subscription lifecycle, usage enforcement
7	**Provisioning & sample product**	Done	Reliable provisioning with retries; reference product service
8	**Frontend portals**	Done	Super Admin and Company Admin screens
–	**Billing (Razorpay)**	Done	Gateway invoices, payment webhooks, payment-driven renewal
9	**Hardening**	Done	Security review, isolation suite, load tests, backup drill
10	**Deployment**	Planned	Production setup, monitoring, runbooks, rollback

Decisions and technology

Topic	Decision
Versions	Latest stable; latest LTS where a choice exists (ADR-0007)
Login provider	Self-hosted Keycloak (identity data stays in OCCPL infrastructure); MFA required for OCCPL staff
Payments	Razorpay; invoices generated by Razorpay, Core stores references
Grace period / retention	7-day grace before suspension; data kept 90 days after cancellation/expiry (configurable)
Architecture	Modular monolith for the Core Platform; products are independent services

Component	Version	Note
Java	25 LTS	Java 27 is newer but has ~6 months of support
Spring Boot	4.1.1	Spring Framework 7, Security 7, Hibernate 7.4, Jackson 3
Angular	22.2	TypeScript 6, Vitest, zoneless
MySQL	9.7 LTS	26.7 is a short-support innovation release
Keycloak	26.8.1	Self-hosted
Redis	8.10	Rate limiting (Phase 3), caching later
Nginx	1.30	Unprivileged container for the portal

Phase details

Phase 1 — Discovery & architecture

Done

Delivered / scope

- Project scope, assumptions, open decisions and risks (PROJECT.md)
- Module boundaries and dependency rules, integration contract for product services (ARCHITECTURE.md)
- About 35-table data model, subscription state machine, usage-limit rules, migration strategy (DATABASE.md)
- About 80 API endpoints with required permissions; standard error format (API_SPEC.md)
- Authentication, authorization and tenant-isolation design (SECURITY.md); 7 architecture decision records

Phase 2 — Foundation

Done

Delivered / scope

- Backend skeleton: standard JSON errors with tracking IDs, login-token validation, CORS allowlist, security headers
- Health checks and metrics on an internal port; structured JSON logs; database migrations
- Portal shell: runtime configuration, API error handling, design tokens (light/dark), lint and formatting
- Docker Compose stack (MySQL, Keycloak, backend, portal); GitHub Actions CI; weekly dependency updates

Verified

- 22 unit/slice tests and 5 integration tests (MySQL 9.7); 14 frontend tests; production build
- Full stack started locally: real Keycloak tokens accepted; wrong audience, issuer or tampered tokens rejected
- Portal loaded in a browser at phone width with no errors (a CSP issue was found and fixed)

Phase 3 — Identity & access

Done

Delivered / scope

- Database tables for users, identities, profiles, companies, memberships, roles, permissions and audit log
- Seeded catalogue: 28 permissions and 5 built-in roles (Super Admin, Platform Support, Company Admin, Manager, User)
- Sign-in mapping: users created or linked on first login only with a verified email; disabled accounts blocked; an email cannot be taken over by a second Keycloak account
- First Super Admin set by a one-time configured email; every change audit-logged
- Two-factor login for OCCPL staff: platform permissions withheld until the login used an authenticator app
- Platform role management API; the last Super Admin cannot be removed
- Company-level checks: another company's data returns 'not found'; suspended companies are read-only
- Endpoints: GET /api/v1/me, PUT /api/v1/me/profile, GET /api/v1/permissions
- Keycloak admin client (create users, required actions, enable/disable, logout)
- Rate limiting per user / per IP using Redis; requests still allowed if Redis is down (failure is counted)

Verified

- 6 application integration tests incl. migrations and seed data on MySQL 9.7

- 15 tenant-isolation tests: cross-company access, role limits, suspended/deactivated states, MFA rule, first-login rules, concurrent first login, last-Super-Admin rule, profile validation
- 3 Keycloak tests: admin client via service account; token audience/issuer checks; first Super Admin with authenticator-app enrolment and OTP login through Keycloak's real login pages
- 2 rate-limit tests with real Redis plus a fail-open test
- Docker stack: sign-in from Swagger UI through Keycloak in a real browser, GET /api/v1/me

Open item
- A dedicated expired-token test (expiry is enforced by the framework's default validator)

Phase 4 — Company & membership management

Done

Delivered / scope
- Companies: create with primary contact and initial Company Admin invitation in one step; search, edit (company admins may change only the display name), activate/suspend/deactivate with history
- Company settings incl. allowed email domains for invitations; contacts (primary, billing, technical)
- Invitations: invite, resend, revoke, accept, automatic expiry; links are one-time and stored only as hashes
- New users get a Keycloak 'set your password' email that returns to the accept link; existing users get the platform's invitation email
- Members: list/search, suspend/reactivate/deactivate, change roles — nobody can grant more than they have, change their own membership, or remove the last Company Admin
- Platform users: list, disable/enable (also in Keycloak), memberships across companies
- Audit log search for OCCPL staff and per company for company admins
- Email outbox with retries; local Mailpit inbox shows every email

Verified
- 13 company/membership tests incl. every negative rule; 3 email outbox tests (delivery, retry, rollback)
- 2 end-to-end invitation tests with real Keycloak and SMTP: new admin sets password via the emailed link and joins; existing user accepts the platform email
- Docker stack: company created over the API, invitation email visible in Mailpit

Open item
- Custom company roles; branded Keycloak email text; Idempotency-Key header; seat limits (Phase 6)

Phase 5 — Product catalogue

Done

Delivered / scope
- Register products (start as draft) with app URL, API URL and the identifier their service accepts in tokens
- Edit, activate (only after a configuration is published), retire and reinstate products; every change audited
- Versioned configuration: each version is checked against a published schema, can never be edited, and can be published or rolled back; configurations that contain secrets are refused
- Features per product: on/off features and limits (seats, API calls, storage, ...) with reset periods

Verified
- 5 configuration-validation tests and 3 URL-rule tests
- 4 catalogue integration tests: registration rules, edits, version publish/rollback, feature rules

Open item
- Per-company values for product settings (Phase 7); product logos (needs safe file uploads)

Phase 6 — Plans, subscriptions & entitlements

Done

Delivered / scope

- Plans with prices per currency, included products and feature limits; published plans can't change (copy instead); archive
- Assign plans to companies with an optional trial; upgrade immediately, downgrade at the end of the period; renew, cancel now or at period end, resume; full history and audit
- Automatic lifecycle every 5 minutes: trial ends, unpaid periods become past due, 7-day grace then suspension, 90 days suspended then expiry; data kept 90 days after cancellation or expiry
- Entitlements follow subscriptions instantly; company suspension blocks access; usage limits counted safely even under heavy parallel use; seat limits stop invitations beyond the plan

Verified

- 38 state-machine tests: every status/event combination
- 10 integration tests incl. plan rules, lifecycle sweeps, plan changes, entitlement merging, usage replay, and 120 parallel requests against a limit of 50 (exactly 50 allowed)

Open item

- Per-product seats (product-service endpoints were delivered in Phase 7, payment-driven renewal with billing)

Phase 7 — Provisioning & sample product

Done

Delivered / scope

- Product services sign in to Core with their own Keycloak client; Core limits each one to its own product
- Service API for products: is this user of this company allowed to use the product or feature? Report usage against limits (safe to repeat)
- When a company gets a product, Core sets the company up in the product automatically; failed calls are retried with increasing waits, permanent failures alert the operations team and can be retried by an admin
- When access ends, the company's data in the product is removed only after the 90-day retention period, and kept if the company subscribes again before then
- Company product list with launch links once the product is ready
- Sample "Notes" product with its own database, showing the full integration

Verified

- 6 integration tests with a fake product: success, slow product, server errors, rejected requests, asynchronous completion, wrong-product callbacks, delayed removal and its cancellation
- 2 sample-product tests; 1 end-to-end test with real Keycloak, Core and the sample product as a separate program with its own database

Open item

- Re-sending configuration to products when a new version is published; Alertmanager rule (Phase 10)

Phase 8 — Frontend portals

Done

Delivered / scope

- Secure sign-in through Keycloak; OCCPL staff must use their authenticator app before staff features unlock
- Super Admin: dashboard, companies, users and staff roles, products with versioned configuration and features, plans with prices and limits, subscriptions, provisioning jobs with retry, audit log
- Company workspace: company details and settings, contacts, product launcher, subscription, users and invitations with roles, usage against limits, audit log
- Invitation emails lead straight into the portal; works on phones and desktops; keyboard accessible

Verified

- 47 frontend tests (sign-in, permissions, forms, plan editor, user management)
- Browser walkthrough of both portals against the full Docker stack with real sign-in and MFA, including automatic setup of the sample product and a company admin joining from the real email

Open item

- Platform settings page (needs a settings API); names instead of ids in a few lists

Billing (Razorpay)

Done

Delivered / scope

- Invoices are created, numbered and emailed by Razorpay; the company pays on Razorpay's secure page (no card details reach OCCPL systems)
- Renewal invoices go out automatically 7 days before a period ends; staff can also issue one, cancel it, or check its payment status at Razorpay
- A paid invoice renews the subscription for exactly the period it was issued for — never twice; paying during a trial keeps the remaining trial days
- Payment notifications from Razorpay are checked for authenticity and processed once even if repeated; forged notifications are refused and recorded
- Company Billing tab with invoices, Pay link and payments; platform-wide invoice list

Verified

- 7 integration tests against a Razorpay stand-in: one invoice per period, gateway failure, forged and repeated notifications, trial conversion, partial payment, expiry, cancel, status check, automatic renewal invoices
- Browser walkthrough: invoice issued from the portal, payment notification, trial converted to active

Open item

- GST on invoices (decision D-11); one live Razorpay test-mode payment; refunds; separate billing permissions

Phase 9 — Hardening

Done

Delivered / scope

- Automatic check of every API endpoint: each one requires the right sign-in and permission; a company can never reach another company's data (always "not found"), also for new endpoints added later
- Independent security review: 8 issues found and fixed (e.g. a way to exceed the plan's user limit, one sign-in token that every product could reuse, a spoofable client address for rate limiting)
- Known vulnerabilities in libraries: 3 critical and 5 high found and fixed by upgrades; automatic scans in the build pipeline from now on
- Load test with 10,000 companies and 1,000,000 users: all response-time targets met up to 210 requests per second on a small 4-processor test machine; the one slow search was fixed (0.5 s → 0.05 s)
- Backups every night plus every 5 minutes; tested restore of the full data in under a minute, including undoing an accidental deletion to the exact moment before it

Verified

- 5 tenant-isolation checks covering every endpoint; regression tests for every review finding
- Measured results: load-tests/RESULTS.md and infra/backup/DRILL.md

Open item

- Repeat the load test on production-like hardware; off-site backup copies and alerts (Phase 10)

Phase 10 — Deployment

Planned

Delivered / scope

- Production deployment with TLS and secrets management
- Monitoring, alerting, runbooks and verified rollback

Risks

#	Risk	Mitigation
R-1	Flyway is officially verified only up to MySQL 9.4	All migrations run on MySQL 9.7 in tests; fall back to MySQL 8.4 LTS if a defect appears
R-2	Spring Boot 4 / Jackson 3 ecosystem is new	Prefer Boot-managed libraries; check compatibility before adding any
R-3	Self-hosted Keycloak must be operated	Two-node setup, backups and upgrade runbook in Phase 10
R-4	Capacity on production hardware unproven	Phase 9 load test met all targets on a small test machine; repeat on staging hardware before launch
R-5	Razorpay connection tested only against a stand-in	One test-mode payment with real Razorpay keys before going live (DEPLOYMENT.md)

Open decisions

#	Decision	Needed by	Default if not answered
D-6	Confirm availability and latency targets and expected peak load	Before launch	99.9% availability; p95 under 300 ms for reads (met in the Phase 9 test)
D-7	Can Company Admins buy or upgrade plans themselves?	Phase 6 / 8	Super Admin assigns plans
D-8	Self-registration or invitation only?	Phase 4	Invitation only
D-9	How users open products (subdomains vs one gateway)	Phase 7	Applied: each product has its own address plus a launch path; single sign-on
D-10	Personal-data retention and export obligations	Before launch	Export and deletion workflows, configurable retention
D-11	GST on invoices: are plan prices tax-inclusive, which rate and code, print the company's GSTIN?	Live payments	None applied today: the plan price is the invoice amount